



INTERNAL COMPLIANCE GAP ASSESSMENT

Findings and Recommended Remediation for the Executive Committee

Prepared by	Prepared for	Report type	Date
Valentine John Ogoshi, GRC Manager	Executive Committee, ValNova Technologies	Internal Gap Assessment	August 6, 2026

1. EXECUTIVE SUMMARY

This assessment looks at how ValNova Technologies is doing against the compliance obligations that now apply to our payment, identity-verification, and government-facing platforms. We measured our current practices against four standards we treat as binding or as targets for certification: the Nigeria Data Protection Act (NDPA) 2023 as implemented by the General Application and Implementation Directive (GAID) 2025, PCI DSS v4.0.1 for the cardholder data environment, ISO/IEC 27001:2022, and the SOC 2 Trust Services Criteria. The aim here is not to point fingers. It is to give the committee an honest picture of where we stand before we bring in an external auditor.

We recorded eight findings: three rated High, four Medium, and one Low. The High-severity ones concern authentication into the cardholder data environment, the legal basis for moving Nigerian personal data to our foreign-hosted platforms, and our outstanding registration with the Nigeria Data Protection Commission (NDPC). None of this is unusual for a company at our stage, and each item can be closed within the timelines in the remediation plan in Section 7. What matters is that we work through them in a planned order, and that the committee backs the ownership and funding needed to close them before our first audit cycle.

I am asking the committee for three things: to endorse the remediation plan in Section 7, to confirm the named owners, and to agree that the three High-severity items are closed before we onboard any further customer or citizen data onto the affected platforms.

2. BACKGROUND AND SCOPE

ValNova Technologies handles cardholder data, citizen data, and sensitive customer records across its payment, identity-verification, and government-facing platforms. As we grow and start serving partners who are themselves regulated or publicly listed, we have to be able to show a solid data-protection and information-security posture. We ran this assessment to see clearly where we stand before our first external audit cycle.

The assessment covered our production environment, the SaaS platforms that process or store regulated data on our behalf, our access-management practices, our governance documentation, and our third-party integrations with

banking, payment-processing, and government partners. We left two things out of this round: physical-security controls at partner premises, and the internal financial-reporting controls that sit with the finance function. We will handle both separately.

3. METHODOLOGY AND APPROACH

We assessed ValNova's current practices against four sources of obligation that we treat as binding or as certification targets: the Nigeria Data Protection Act 2023 as implemented by the GAID 2025, PCI DSS v4.0.1 for the cardholder data environment, ISO/IEC 27001:2022 for the information-security management system, and the SOC 2 Trust Services Criteria. We gathered the evidence three ways: by reviewing the configuration of production and cloud systems, by going through our policies and records, and by sitting down with the engineering and operations leads.

Every finding is tied to the specific standard and clause it touches, given a severity rating, and paired with clear remediation steps, a named owner, and a target date. We rated severity as follows. High means the finding creates direct regulatory exposure, a live security risk to regulated data, or a blocker to certification, so it has to be dealt with first. Medium means a control weakness an auditor would raise, which we should close within the quarter. Low means a gap worth closing on the way to a mature programme, but one that carries limited immediate risk. Appendix A sets out the full scale.

4. REGULATORY REQUIREMENTS ASSESSED

The table below sets out the standards we assessed ValNova against, and why each one applies to us. It gives the committee the full picture of what we are answerable to before reading the findings.

Standard	Applies to	Why it applies to ValNova
NDPA 2023 / GAID 2025	All personal data of Nigerian data subjects	ValNova processes citizen and customer personal data at scale, which brings it within the Act and, given the volume and sensitivity, the obligations placed on data controllers of major importance.
PCI DSS v4.0.1	The cardholder data environment	ValNova handles cardholder data as part of its payment-processing services, so the systems that store, process, or transmit that data must meet PCI DSS.
ISO/IEC 27001:2022	The information-security management system	ValNova intends to certify its ISMS to reassure regulated and listed partners; the standard sets the governance, access, and supplier controls assessed here.
SOC 2 (Trust Services Criteria)	Security and availability of customer systems	Prospective partners increasingly ask for a SOC 2 report during due diligence, so in practice our sales cycle depends on having one.

5. SUMMARY OF FINDINGS

The table below lists all eight findings with their domain, the standard they relate to, and their severity rating. Detailed observations and recommendations follow in Section 6.

#	Finding	Primary Domain	Standard / Clause	Severity
---	---------	----------------	-------------------	----------

#	Finding	Primary Domain	Standard / Clause	Severity
1	Multi-factor authentication not enforced across the cardholder data environment	Access control	PCI DSS v4.0.1 Req 8.4.2	High
2	No approved cross-border data-transfer instrument for foreign-hosted platforms	Data privacy	NDPA 2023 / GAID 2025	High
3	NDPC data controller registration and annual audit return outstanding	Regulatory filing	NDPA 2023 / GAID 2025	High
4	Access reviews for privileged accounts performed ad hoc, not on a defined cycle	Access control	ISO/IEC 27001:2022 A.5.18	Medium
5	Information security policy set incomplete and not formally approved	Governance	ISO/IEC 27001:2022 Cl. 5.2	Medium
6	Vendor and third-party risk assessments not conducted for critical integrations	Third-party risk	ISO/IEC 27001:2022 A.5.19	Medium
7	Audit logging and monitoring coverage incomplete across production systems	Logging & monitoring	PCI DSS v4.0.1 Req 10; SOC 2 CC7.2	Medium
8	Security awareness training not delivered on a scheduled, tracked basis	People	PCI DSS v4.0.1 Req 12.6; ISO A.6.3	Low

Rating summary: 3 High, 4 Medium, 1 Low.

6. DETAILED FINDINGS AND RECOMMENDATIONS

Finding 1: MFA not enforced across the cardholder data environment

Severity: **High** **Standard:** PCI DSS v4.0.1 Requirement 8.4.2

Observation. Multi-factor authentication is enforced for remote administrative access but is not applied consistently to all access into the cardholder data environment. PCI DSS v4.0.1 requires MFA for all access into the CDE, not only administrative or remote access, across all system components including cloud consoles, servers, and endpoints.

Business impact. Single-factor access to systems that touch cardholder data is one of the most common causes of payment-data breaches, and an assessor would flag it straight away. While it stays open, it blocks our PCI attestation and leaves the payment platform exposed to credential-based attacks.

Recommended steps.

- Enumerate every access path into the CDE, including cloud provider consoles, bastion hosts, databases, and application admin panels.
- Enforce MFA on all human and service-account access to those paths, using phishing-resistant factors where the platform supports them.
- Align the supporting password policy with Requirement 8.3.6 (minimum twelve characters, alphanumeric).
- Record the enforced configuration as evidence and add an automated check so any drift is detected quickly.

Finding 2: No approved cross-border transfer instrument for foreign-hosted platforms

Severity: **High** **Standard:** NDPA 2023, as implemented by GAID 2025

Observation. Several of our platforms process Nigerian personal data on infrastructure hosted outside Nigeria. We do not currently hold an approved transfer instrument, such as standard contractual clauses, with those vendors, and no country in scope holds an NDPC adequacy decision that we could rely on instead.

Business impact. Under the NDPA, moving Nigerian personal data abroad without a lawful basis is a straight compliance breach that can draw regulatory action. As a processor of citizen and cardholder data, this is one exposure we really cannot afford to leave open.

Recommended steps.

- Identify every vendor and platform that processes Nigerian personal data outside the country.
- Execute NDPA-compliant data processing agreements incorporating standard contractual clauses for cross-border transfer with each of them before any further data flows.
- Confirm each vendor's data residency and sub-processor locations, and prefer regional hosting options where offered.
- Document the lawful transfer basis for each platform so it can be produced on request.

Finding 3: NDPC registration and annual audit return outstanding

Severity: **High** **Standard:** NDPA 2023, as implemented by GAID 2025

Observation. ValNova has not completed its registration with the Nigeria Data Protection Commission as a data controller of major importance, and the associated annual compliance audit return has not been prepared. Given the volume and sensitivity of the data we process, these obligations apply to us.

Business impact. Failure to register and file is a standalone regulatory breach independent of how well our technical controls perform. It also signals to partners and regulators that our data-protection programme is not yet formalised, which undermines trust during due diligence.

Recommended steps.

- Complete NDPC registration as a data controller of major importance.
- Engage a licensed Data Protection Compliance Organisation where required to prepare and file the annual audit return.
- Document the cross-border transfer basis from Finding 2 within that return.
- Set a recurring calendar control so future filings are never missed.

Finding 4: Privileged access reviews performed ad hoc rather than on a defined cycle

Severity: **Medium** **Standard:** ISO/IEC 27001:2022 Annex A 5.18 (Access rights)

Observation. Access to privileged and administrative accounts is granted appropriately at onboarding, but there is no scheduled review to confirm that access remains appropriate over time. Reviews happen only when someone remembers or when a role changes.

Business impact. Without a regular review, access accumulates as people change roles, creating standing privilege that neither we nor an auditor can justify. This is a routine SOC 2 and ISO 27001 finding and a common path to insider and account-takeover risk.

Recommended steps.

- Define a quarterly access-review cycle covering all privileged and administrative accounts.
- Assign each system an accountable reviewer who confirms or revokes access in writing.
- Retain the signed-off review as audit evidence.
- Automate the review workflow through the compliance platform once it is in place.

Finding 5: Information security policy set incomplete and not formally approved

Severity: **Medium** **Standard:** ISO/IEC 27001:2022 Clause 5.2 (Policy)

Observation. We operate with a partial set of security policies, some in draft and some undated, and there is no evidence of formal management approval or a scheduled review cycle. Key policies such as access control, acceptable use, incident response, and data retention are either missing or not ratified.

Business impact. An incomplete, unapproved policy set is one of the first things an auditor checks, and gaps here tend to pull other control findings along with them. It also leaves staff without clear, authoritative guidance on how regulated data should be handled.

Recommended steps.

- Complete the core policy set, including access control, acceptable use, incident response, data retention, and change management.
- Obtain documented executive approval and assign each policy an owner and a review date.
- Publish the approved policies where all staff can reach them and acknowledge them.
- Set an annual review cycle for the full set.

Finding 6: Third-party risk assessments not conducted for critical integrations

Severity: **Medium** **Standard:** ISO/IEC 27001:2022 Annex A 5.19 (Supplier relationships)

Observation. We integrate deeply with banks, payment processors, and government agencies, but we do not run a formal security risk assessment of these partners before or during the relationship. Onboarding relies on the commercial relationship rather than a documented risk review.

Business impact. Our compliance and security posture depends on partners we have not formally assessed. A weakness at a critical integration partner becomes our incident, and the absence of assessments is a finding auditors raise and regulators expect us to have addressed.

Recommended steps.

- Build an inventory of critical third parties and the data each one touches.
- Introduce a standard security assessment at onboarding and on a defined recurring basis thereafter.
- Record findings, required remediations, and residual risk for each partner.
- Move critical vendors into continuous monitoring once the privacy and vendor-risk platform is live.

Finding 7: Audit logging and monitoring coverage incomplete across production systems

Severity: **Medium** **Standard:** PCI DSS v4.0.1 Requirement 10; SOC 2 CC7.2

Observation. Logging is enabled on some but not all production systems, and there is no consistent central aggregation or alerting. Coverage of access to systems handling cardholder and citizen data is partial, and log retention is not defined uniformly.

Business impact. Without complete logging and active monitoring, we cannot reliably detect or investigate an incident, and we cannot demonstrate the detective controls that both PCI DSS and SOC 2 require. This weakens both our security response and our audit position.

Recommended steps.

- Extend logging to all in-scope production systems, with priority on those touching cardholder and citizen data.
- Aggregate logs centrally and define a retention period consistent with PCI DSS.
- Configure alerting for the security events that matter most and assign response ownership.
- Test the alerting path so we know detection actually works before we need it.

Finding 8: Security awareness training not delivered on a scheduled, tracked basis

Severity: **Low** **Standard:** PCI DSS v4.0.1 Requirement 12.6; ISO/IEC 27001:2022 Annex A 6.3

Observation. Security awareness is covered informally at onboarding but is not delivered as a scheduled programme, and completion is not tracked. There is no record we could show an auditor of who has been trained and when.

Business impact. People are still the most common way attackers get into fintech firms. Ad hoc training that nobody tracks leaves staff under-prepared for phishing and social engineering, and having no completion records is itself a control gap under both standards.

Recommended steps.

- Adopt a scheduled security awareness programme delivered at onboarding and at least annually.
- Track completion centrally and follow up on non-completion.
- Include role-specific content for engineering and for staff who handle cardholder or citizen data.
- Retain completion records as audit evidence.

7. REMEDIATION PLAN AND OWNERSHIP

The plan below sequences remediation so that the three High-severity findings are addressed first, with the Medium and Low findings following on defined timelines. Timeframes run from the date the committee endorses this report. I will report progress against these targets at each monthly executive review.

#	Priority remediation action	Owner	Target
1	Enforce MFA on all human and administrative access to the CDE and supporting systems	GRC Manager / IT	30 days
2	Execute standard contractual clauses and DPAs with all foreign-hosted vendors before further data flows	GRC Manager / Legal	45 days
3	Complete NDPC registration and prepare the annual compliance audit return	GRC Manager / Legal	60 days
4	Stand up a quarterly privileged-access review with documented sign-off	GRC Manager / IT	45 days
5	Finalise, approve, and publish the full information security policy set	GRC Manager / Exec Sponsor	60 days
6	Onboard critical vendors into a formal third-party risk assessment cycle	GRC Manager	90 days
7	Extend centralised logging and alerting to all in-scope production systems	IT / Engineering	90 days
8	Roll out scheduled, tracked security awareness training for all staff	GRC Manager / People Ops	90 days

Sequencing note. Findings 1 to 3 are the gating items and should be closed before further regulated data is onboarded onto the affected platforms. Findings 4 to 8 proceed in parallel and are scheduled so as not to overload the engineering team during the same window.

8. NEXT STEPS

Closing the findings is the main task, but a few more steps turn this assessment from a one-off snapshot into something we keep running:

- Committee endorsement of this report and confirmation of the named owners at the next executive meeting.
- A monthly progress review against the remediation targets, led by the GRC Manager, until all findings are closed.
- Re-testing of each High-severity finding once remediation is reported complete, with evidence retained for the future audit.
- Selection and rollout of a compliance-automation platform to move access reviews, vendor monitoring, and evidence collection onto a continuous footing.
- A follow-up gap assessment before the first external audit to confirm the programme is audit-ready.

9. RECOMMENDATION TO THE COMMITTEE



None of these findings should alarm the committee. They are the normal gaps a fintech at our stage carries, and we can close all of them within the timelines in Section 7. The real value in raising them now, ourselves, is that we fix them on our own terms instead of hearing about them from an external assessor or, worse, after an incident.

My recommendation is that the committee endorse the remediation plan, confirm the named owners, and release the modest budget we need for the compliance tooling and for legal support on the cross-border and NDPC items. I would also ask that we treat the three High-severity findings as gating, meaning we close them before onboarding any further regulated data onto the affected platforms. If we do that, we go into our first SOC 2 and PCI DSS cycles standing on solid ground, and I will report progress against each target at the monthly executive review.

Prepared and submitted by,

Valentine John Ogoshi

GRC Manager, ValNova Technologies

10. APPENDIX

Appendix A: Severity rating scale

Each finding was rated against the scale below, which weighs regulatory exposure and the likelihood of harm to regulated data.

Rating	Definition and expected response
High	Direct regulatory exposure, a live security risk to regulated data, or a barrier to certification. Resolve first, before further regulated data is onboarded onto the affected platforms.
Medium	A control weakness an auditor would raise. Close within the current quarter.
Low	A gap worth closing to reach a mature, sustainable programme, carrying limited immediate risk. Close as capacity allows.

Appendix B: Glossary of key terms

Term	Meaning
CDE	Cardholder Data Environment. The systems that store, process, or transmit payment-card data and anything connected to them.
GAID 2025	General Application and Implementation Directive 2025, which operationalises the NDPA.
ISMS	Information Security Management System. The set of policies and controls certified under ISO/IEC 27001.
MFA	Multi-Factor Authentication. Access that requires more than one independent authentication factor.
NDPA	Nigeria Data Protection Act 2023, Nigeria's primary data-protection law.
NDPC	Nigeria Data Protection Commission, the regulator that administers the NDPA.
PCI DSS	Payment Card Industry Data Security Standard, the control set for protecting cardholder data.
SOC 2	A reporting framework based on the Trust Services Criteria, commonly requested during vendor due diligence.